6. Risk Treatment Recommendations

6.1 Risk Treatment Overview

The IT Security Risk Assessment identified 12 distinct security risks requiring proposed corrective action under the simulated production scenario.

A Risk Treatment Plan was developed to document recommended remediation activities, treatment priorities, simulated risk owners, and proposed validation methods.

All 12 risks were assigned a proposed treatment strategy of **Mitigate**.

Risk mitigation involves implementing safeguards or corrective actions intended to reduce the likelihood or impact of an identified risk.

The recommendations in this section are based on the technical evidence collected during the Greenbone vulnerability assessment and the provisional inherent risk ratings documented in the Risk Register.

Because the assessment was conducted in an intentionally vulnerable laboratory environment, these recommendations are illustrative and have not been approved by an actual organization's management.

6.2 Risk Treatment Priorities

Treatment priorities were established using the five-point likelihood and impact scoring methodology described in Section 3.

Treatment Priority	Inherent Risk Rating	Number of Risks
P1	Critical	9
P2	High	3
Total		**12**

P1 — Critical Priority

These risks should receive the earliest management attention under the simulated production scenario.

They include weaknesses involving privileged access, backdoors, remote command execution, unsupported technology, and vulnerable application components.

P2 — High Priority

These risks also require corrective action but were assigned lower provisional inherent risk scores.

They include insecure rexec functionality, Apache Tomcat Ghostcat, and weak VNC authentication.

These priorities are recommendations rather than approved organizational remediation deadlines.

Actual remediation sequencing should consider business criticality, exploitability, existing controls, operational dependencies, and available resources.

6.3 Detailed Risk Treatment Recommendations

The following table summarizes the recommended treatment actions for all 12 registered risks.

Risk ID	Security Weakness	Priority	Recommended Treatment	Proposed Validation
RISK-001	Distributed Ruby Remote Code Execution	P1	Disable unnecessary DRb functionality or restrict access to trusted systems; update or replace vulnerable components.	Verify service restrictions and repeat relevant vulnerability checks.
RISK-002	Ingreslock Backdoor	P1	Remove the backdoor and investigate system integrity; rebuild from a trusted image where compromise is suspected.	Confirm the backdoor is absent and root-level remote execution is no longer possible.
RISK-003	Passwordless rlogin Root Access	P1	Disable rlogin and prohibit passwordless remote root access; use approved secure administration methods.	Confirm rlogin is disabled and unauthorized root authentication fails.
RISK-004	TWiki XSS and Command Execution Vulnerabilities	P1	Upgrade or replace the vulnerable TWiki application and apply secure application configuration requirements.	Verify the deployed version and repeat relevant vulnerability checks.
RISK-005	Insecure rexec Service	P2	Disable rexec and replace it with an approved encrypted remote administration protocol.	Confirm TCP port 512 is no longer exposing rexec.
RISK-006	Unsupported Ubuntu 8.04 Operating System	P1	Migrate applications and services to a supported operating system or retire the affected system.	Verify the replacement system runs a supported operating system and passes applicable security checks.

Risk ID	Security Weakness	Priority	Recommended Treatment	Proposed Validation
RISK-007	vsftpd Backdoor	P1	Remove the affected FTP software and replace it with a trusted, supported version or eliminate the service.	Confirm the affected service and backdoor behavior are no longer present.
RISK-008	MySQL Root Empty Password	P1	Set a strong, unique database administrator password and restrict database administrative access.	Verify authentication with an empty password fails and approved credentials are required.
RISK-009	Apache Tomcat Ghostcat	P2	Update vulnerable Tomcat components; disable or restrict the AJP connector where unnecessary.	Confirm unauthorized access to `/WEB-INF/web.xml` is blocked.
RISK-010	DistCC Remote Command Execution	P1	Disable DistCC if unnecessary or restrict it to explicitly authorized systems and users.	Verify unauthorized remote command execution is no longer possible.
RISK-011	Weak VNC Authentication	P2	Replace the weak password, restrict VNC access, and use stronger remote administration controls.	Confirm the previous password fails and access restrictions are enforced.
RISK-012	PostgreSQL Default Credentials	P1	Replace default credentials, restrict database access, and review administrative account permissions.	Verify default credentials no longer provide access.

These recommendations are intended to address the underlying security weaknesses rather than merely suppress scanner findings.

For example, closing a network port may reduce exposure, but a system containing a backdoor may also require integrity investigation or rebuilding from a trusted source.

6.4 Recommended Remediation Initiatives

The 12 individual risks can be organized into five coordinated remediation initiatives.

Initiative 1 — Remove Backdoors and Unauthorized Execution Paths

Associated Risks: RISK-001, RISK-002, RISK-007, RISK-010

Recommended Actions:

1. Identify and remove unauthorized or unnecessary remote execution services.
2. Replace affected software with trusted, supported versions.
3. Restrict access to legitimate remote execution functionality.
4. Investigate system integrity where backdoor behavior suggests potential compromise.
5. Validate that unauthorized command execution is no longer possible.

Expected Risk Reduction:

Reduced exposure to unauthorized system commands, privilege misuse, and potential system compromise.

Initiative 2 — Strengthen Authentication and Privileged Access

Associated Risks: RISK-003, RISK-008, RISK-011, RISK-012

Recommended Actions:

1. Eliminate empty, default, and weak passwords.
2. Disable passwordless remote root access.
3. Restrict privileged database and system accounts.
4. Apply strong authentication requirements to remote administration services.
5. Review account permissions and remove unnecessary privileges.

Expected Risk Reduction:

Reduced likelihood of unauthorized authentication, privileged access, and compromise of sensitive information.

Initiative 3 — Replace Unsupported and Vulnerable Software

Associated Risks: RISK-004, RISK-006

Recommended Actions:

1. Identify unsupported operating systems and applications.
2. Establish migration or replacement plans.
3. Upgrade vulnerable application components.
4. Apply approved software lifecycle management requirements.
5. Validate that replacement systems meet applicable security standards.

Expected Risk Reduction:

Reduced exposure to known vulnerabilities and improved ability to maintain security updates.

Initiative 4 — Eliminate Insecure Remote Administration Services

Associated Risk: RISK-005

Recommended Actions:

1. Disable rexec.
2. Replace insecure legacy protocols with approved encrypted alternatives.
3. Restrict administrative connectivity to authorized management networks.
4. Review systems for other unnecessary legacy services.
5. Verify that insecure services are no longer accessible.

Expected Risk Reduction:

Reduced exposure to credential disclosure and unauthorized remote administration.

Initiative 5 — Secure Application Connectors and Network Exposure

Associated Risk: RISK-009

Recommended Actions:

1. Update vulnerable Apache Tomcat components.
2. Disable the AJP connector if it is not required.
3. Restrict access to necessary application interfaces.
4. Review application connector configuration against approved standards.
5. Confirm that protected application files cannot be retrieved without authorization.

Expected Risk Reduction:

Reduced exposure to unauthorized application file disclosure and related exploitation paths.

These initiatives provide a management-level view of the remediation program while maintaining traceability to individual Risk Register entries.

6.5 Proposed Risk Ownership and Accountability

The Risk Treatment Plan assigns simulated owners to the documented risks.

Ownership is intended to illustrate how responsibility for remediation could be distributed within an organization.

Examples of relevant roles include:

Functional Role	Illustrative Responsibilities
Infrastructure Manager	Operating system maintenance, server hardening, and removal of unauthorized services
Application Manager	Application upgrades, application configuration, and service security
Database Administrator	Database authentication, privileged database access, and database configuration
Security Team	Vulnerability tracking, remediation coordination, and validation support
IT Management	Resource allocation, remediation prioritization, and escalation of unresolved risks

These roles are illustrative.

No actual organizational personnel were assigned responsibility, and no management approvals were obtained.

In a production environment, each risk should have an accountable owner with authority to coordinate treatment and report progress.

6.6 Remediation Tracking and Status

At the conclusion of the assessment, the Risk Treatment Plan reflected the following status:

Treatment Metric	Assessment Result
Registered Risks	12
Risks With Recommended Treatment	12
Risks Assigned Mitigation Strategy	12
Risks With Verified Remediation	0
Risks With Assessed Residual Risk	0

All 12 risks remained **Open**.

Remediation activities were recorded as **Not started**, and target completion dates were **Not assigned**.

The absence of completed remediation is consistent with the assessment's educational scope: the Metasploitable target was intentionally maintained in a vulnerable state.

Accordingly, this report does not claim that the identified weaknesses have been corrected.

6.7 Recommended Remediation Validation Process

If corrective actions were implemented in a production environment, remediation should be validated before the corresponding risks are closed.

A proposed validation process would include the following steps.

Step 1 — Document Corrective Action

Record the changes performed, implementation date, responsible owner, and supporting evidence.

Step 2 — Verify the Security Configuration

Confirm that the affected service, account, software version, or configuration has been corrected.

Step 3 — Perform Targeted Retesting

Repeat relevant technical checks to determine whether the original weakness remains exploitable or detectable.

Step 4 — Conduct Follow-Up Vulnerability Scanning

Where appropriate, perform a new vulnerability scan to identify remaining or newly introduced findings.

Step 5 — Review Validation Evidence

A designated reviewer should examine the results and determine whether the remediation sufficiently addresses the identified risk.

Step 6 — Update the Risk Register

Document the remediation outcome, supporting evidence, remaining concerns, and revised status.

Step 7 — Assess Residual Risk

Evaluate any remaining risk after considering implemented safeguards and their demonstrated effectiveness.

Successful validation should be supported by evidence rather than relying solely on a remediation ticket marked complete.

6.8 Residual Risk and Risk Acceptance

Residual risk is the risk remaining after relevant controls or corrective actions have been considered.

This assessment did not calculate residual risk because:

- No remediation actions were implemented.
- No compensating controls were formally evaluated.
- No organizational control effectiveness testing was performed.
- No management risk acceptance decisions were obtained.

As a result, all 12 risks retain the status **Residual Risk: Not assessed**.

In an actual organization, management would need to review any remaining exposure and determine whether further mitigation, risk acceptance, or another treatment strategy was appropriate.

Risk acceptance should be documented and approved by personnel with the appropriate authority.

No risk acceptance is implied by the recommendations in this report.

6.9 Management Reporting Recommendations

For a production environment, management reporting should provide visibility into remediation progress and unresolved exposure.

Recommended reporting measures include:

Metric	Management Purpose
Open Risks by Severity	Identifies the distribution of unresolved business risks
Open Risks by Priority	Highlights items requiring the earliest attention
Remediation Progress	Tracks corrective actions against approved plans
Overdue Remediation Items	Identifies missed target dates and potential escalation needs
Risks Awaiting Validation	Separates implemented changes from verified risk reduction
Residual Risk Ratings	Shows remaining exposure after controls are evaluated
Approved Risk Exceptions	Provides visibility into formally accepted risks

The Executive Dashboard developed for this project establishes a starting point for this type of reporting.

However, because no remediation deadlines, management approvals, or completed corrective actions were available, the dashboard reflects assessment status rather than operational remediation performance.

6.10 Risk Treatment Conclusion

The Risk Treatment Plan provides a structured approach for addressing the 12 security risks identified during the vulnerability assessment.

Nine risks were assigned P1 priority and three were assigned P2 priority under the simulated production scenario.

The proposed actions emphasize removing backdoors, restricting unauthorized remote execution, strengthening authentication, replacing unsupported software, eliminating insecure services, and securing application connectors.

Each registered risk includes a recommended mitigation action and proposed validation method.

No remediation was performed, no corrective action was verified, and residual risk was not assessed.

The recommendations therefore represent a proposed risk treatment plan rather than evidence of completed security improvements.

The final section summarizes the assessment's limitations, overall conclusions, and potential next steps.